Monthly Intelligence Dispatch

January 2021

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly newsletter by Group-IB, an international company that specializes in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, data leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

Key findings

- According to Group-IB, the **Classiscam** fraud scheme expanded beyond Russia and started to be active in the CIS, Europe, and the US.
- Researchers at Cyble discovered data relating to the COVID-19 vaccine allegedly stolen from the **European Medicines Agency (EMA)** leaked in the dark web.
- The Reserve Bank of New Zealand fell victim to a hacker attack.
- Group-IB specialists discovered a database containing **30,000** compromised cards, most of them belonging to UK banks.
- **Capcom**, a game developer, published new details of a recent cyberattack that affected gamers' data.
- Experts at Check Point discovered a botnet called **FreakOut**, which targets unpatched applications running on top of Linux systems.
- Experts at Group-IB identified the type of malware used in an attempt to hijack the account of the popular Telegram channel **Baza** (312,000 subscribers).
- Europol and the FBI conducted a large-scale operation to take down the **Emotet** botnet.

Classiscam

In 2020, the Classiscam fraud scheme expanded beyond Russia and became active in the CIS, Europe, and the US. According to Group-IB, no fewer than 20 large groups currently operate in Romania, Bulgaria, France, Poland, the Czech Republic, the US, Ukraine, Uzbekistan, Kyrgyzstan, and Kazakhstan. Another 20 groups are stealing users' money and bank card data using fake websites mimicking those of popular delivery services and marketplaces.

CERT-GIB and Group-IB Digital Risk Protection specialists detected the Classiscam scheme being used in Russia for the first time as early as the summer of 2019 after a number of victims had reached out. We were the first to release a report in May. The fraudulent activity peaked in 2020, which happened for several reasons: the pandemic; the shift to working remotely; and an increase in the demand for online purchases (about 30%–40% on average) and, therefore, delivery services. In the summer of 2020, Group-IB took down 280 scam pages that exploited the topic of delivery services. By December 2020, their number rose 10-fold and reached up to 3,000 websites.

The overall revenue of all groups that used this fraud scheme in 2020 is estimated at more than $6.2 million. Group-IB forecasts that by the end of the year the damage from the scheme may increase, unlike in Russia where delivery services, free online bulletin boards, and real estate rental resources were the first to face Classiscam. The vast majority of users and security service employees at international companies are not currently ready to counteract this type of fraud.

Threat actors have also started to search for new niches. For instance, fake resources imitating those of popular car and housing rental websites and betting firms have appeared online.

EMA

Researchers at the threat intelligence firm Cyble discovered data relating to the COVID-19 vaccine allegedly stolen from the **European Medicines Agency (EMA)** leaked in the dark web. In early December, the **EMA** reported a cyberattack, but did not reveal the details. The goal of the cyber espionage operation is clear: the agency has access to sensitive and confidential information, including quality, safety, and effectivity data resulting from COVID-19 vaccine trials.

Kawasaki

The Japanese giant **Kawasaki Heavy Industries,** which manufactures defense equipment, helicopters, and aircraft parts for Boeing, Embraer, and Bombardier, confirmed the possibility of a data breach. An internal audit revealed that the company's servers had been accessed via an overseas office in Thailand. The first instance of unauthorized access was detected on June 11, 2020. In addition, further unauthorized access via satellite offices in Indonesia, the Philippines, and the US was detected. Journalists believe that the cyberattack may have been launched in an effort to obtain "defense-related information" and may be linked to Pyongyang.

Reserve Bank of New Zealand	The Reserve Bank of New Zealand admitted that it fell victim to a hacker attack. The threat actors gained access to a file sharing service that the bank used for storing and sharing confidential information. While the attack was quickly detected and localized, the bank does not rule out that some commercially and personally sensitive information may have been compromised. The bank said that the affected system had been secured and taken offline until the end of initial investigations.
entershop	During their monitoring of card shops, Group-IB specialists discovered a new database called 01\/7 RESIN TX. DALLAS 7 212 on entershop. The database, whose overall price is estimated at **$1.8** million, contained **30,000** cards, with 83.4% of them belonging to UK issuing banks. The card data was published in DUMPS format, i.e. unauthorized digital copies of magnetic stripe information, such as card number, expiration date, name, and CVV/CVC. Card data can be breached through malware and by skimming POS terminals and ATMs.
Huyndai	The data of 1.3 million Russian owners of Hyundai cars appeared on hacker forums. The data includes the car owners' home addresses and information about purchased cars and car part orders. Threat actors can use the leaked information to steal cars or send out spam messages. The price of the database is $2,000. Security specialists believe the leak may have been caused by a vulnerability in a server of the South Korean car maker.

OpenWRT	OpenWRT, an open-source project that offers free firmware for home routers reported a data breach. The intruder used the account of an OpenWRT administrator. Although the account had "a good password," additional security provided by two-factor authentication (2FA) was not active. The attacker was not able to download the full forum database, but they obtained a list of users that included handles and email addresses. Forum users' passwords were not affected, but OpenWRT still reset passwords and flushed API keys.
Capcom	The game developer Capcom, known for major projects such as Resident Evil, Street Fighter, and Dark Stalkers, revealed new information about a recent cyberattack in which gamers' data had been breached. The corporation says threat actors compromised the data of about 400,000 users. The attack against Capcom was detected in November 2020. At the time, the game developer announced an investigation into the incident and said that the operation of all systems was temporarily shut down. It turned out that the malware operators uploaded ransomware to the Japanese corporation's system and encrypted data on its servers.

Hunter Stealer

Experts at Group-IB identified the type of malware used in an attempt to hijack the account of a cofounder of the popular Telegram channel Baza (312,000 subscribers). In addition, the admins of another dozen channels were targeted, but with different malware. The Baza attack involved Hunter, a fairly primitive stealer that automatically collects account data on infected computers and sends it to threat actors. The stealer has often been used to steal the credentials of GTA San Andreas Online gamers. The malware targets devices running Windows, which is the reason why its operators were insistent in asking the Baza channel owner to open their archive on a desktop computer rather than an iPhone, which the owner rightly did not do. In their attacks on other Telegram channel owners, threat actors sent a “Promo-Video” file with REDLINE, a more sophisticated stealer, within. This malware family is also used for stealing Telegram-related data, namely configuration files that make it possible to restore a session on another device.

SolarWinds

A joint investigation by SolarWinds and information security experts revealed that a special malicious program was responsible for inserting the Sunburst backdoor into software updates distributed from the Orion platform. The authors of the attack against the IT service provider deployed this code in the Orion build environment as early as September 2019. The initial assumption was that the SolarWinds network breach occurred at the beginning of last year. The threat actors gained access to the Orion monitoring platform, more specifically to the system for building software and creating digital signatures for code. The end goal of the attack was to penetrate the IT infrastructure of SolarWinds customers, which the attackers achieved by inserting a backdoor into updates created using Orion. According to some estimates, the breach of the platform affected tens of thousands of subscribers. Further investigation into the attack revealed that the threat actors had used special code (tracked as Sunspot by CrowdStrike) to stealthily insert a backdoor that security experts named Sunburst. After being installed on the server, it grants itself debugging privileges and starts to intercept Orion build processes.

FreakOut

Check Point experts discovered a botnet called FreakOut, which targets unpatched applications running on top of Linux systems. First seen in November 2020, the FreakOut botnet actively scans networks for TerraMaster data storage units, web applications built on top of the Zend PHP Framework, and websites running the Liferay Portal content management system. Once target applications are found, the FreakOut operators use exploits for three relatively recent vulnerabilities to gain control of the underlying Linux system. Because the vulnerabilities are fairly recent, there is a high chance that FreakOut exploitation attempts are succeeding as many systems could still be lagging behind on their patches. Once FreakOut gains access to a system, its immediate step is to download and run a Python script that connects the infected devices to a remote IRC channel where the attackers can send commands and orchestrate attacks.

The researchers say that the malware functions can be combined to perform various operations, like launching DDoS attacks, installing cryptocurrency miners, turning infected bots into a proxy network, or launching attacks on the internal network of an infected device. Moreover, the researchers found several clues in the FreakOut code that allowed them to track down its creator, a person who goes online by the nickname Freak. According to Check Point, this person is linked to Fl0urite, the creator of the now defunct botnet N3Cr0m0rPh, which used to be sold on hacking forums and targeted Windows devices. Judging by an old post, many of the older botnet's features are identical to the ones found in FreakOut.

Arrests and sentences

Emotet

Emotet, one of the world's most dangerous botnets, was taken down. The takedown operation, named Ladybug, is the result of a collaborative effort between the FBI, Europol, and authorities in the UK, the Netherlands, Canada, and Ukraine: they took control of Emotet's infrastructure, which spanned more than 90 countries.

First discovered in 2014, Emotet became one of the most active threats among malware. Malicious programs were mainly distributed through email spam and malicious Word, Excel, etc. Emails could be disguised as invoices, shipping notices, account security warnings, invitations to parties, or information about COVID-19. In other words, the hackers closely followed global trends and always improved their decoy emails.

Emotet started as a typical banking Trojan, but the threat evolved into a powerful loader with multiple modules and its operators started to actively cooperate with other threat groups. After penetrating a victim system, Emotet used the infected machine for spamming and installed various malicious programs on the device. These often were banking Trojans, such as Trickbot; cryptocurrency miners; info stealers; and ransomware, such as Ryuk.

In their report, Europol calls Emotet the "world's most dangerous malware" and "one of most significant botnets of the past decade." The law enforcers believe that the botnet's takedown is one of the biggest operations of this kind and will have a significant impact on the entire criminal world.

Forecasts and warnings

- Seven out of top ten companies in terms of market capitalization are from the IT industry. They develop services, products, and local and cloud software whose source code is one of their most valuable assets. Security incidents related to source code occur constantly, with Nissan and Microsoft being recent examples. The most common causes of source code breaches are security misconfiguration (e.g., a publicly available web service) and authentication issues (lack of two-factor authentication, weak passwords, or misconfigured secret stores).
- Experts believe that Telegram's security might become weaker if the app is removed from the App Store and Google Play. Users will move to the messaging app's web version, where the number of phishing attacks may rise. Threat actors may also exploit browser vulnerabilities: if a browser has a vulnerability, there is a chance that it will be "inherited" in the application's web version. In addition, third parties may gain access to conversations because of extensions (e.g., dishonest ad blockers or programs for bypassing website blocking).
- If a Telegram channel owner does not have app passcode enabled, threat actors will find it easy to restore a given session and change the Telegram channel owner. There is no point in setting a passcode for Telegram while the computer is infected, since malware may have keylogging capabilities. The PC should only be used after the malicious code is eliminated. The conclusion is simple: do not open suspicious messages, archives, and links and do not use operating systems in which stealers feel at home.
- Regularly update your operating system to avoid being a victim of malware. Use strong, unique, and random passwords that are at least eight characters long.

If you wish to receive more detailed information about a specific incident, threat, or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+65 3159 3798
+7 495 984 33 64
intelligence@group-ib.com